

Week 11 Project Report

Computer Security Software

CS 475 Introduction to Computer Security
Maria Nyolcas

May 2026

Introduction

This report presents the Week 11 deliverable of the continuous security portfolio: a security-software taxonomy, a practical endpoint-tool evaluation, and an advisory recommendation for a university department. All activities were conducted in a legal lab setting using only safe artefacts (EICAR) and local infrastructure. Findings are mapped to the NIST Cybersecurity Framework (CSF) and CIS Controls v8.

Part A - Security Software Landscape (Theory)

A-1 Major Categories and Problem Mapping

The field of computer security software has no single universal taxonomy. The groupings below reflect both academic literature and industry practice, each addressing a distinct threat class and sitting at a specific layer of the infrastructure.

Category (acronym)	Problem solved	NIST CSF	Key limitation
AV / EDR	Malicious code on endpoints	Protect, Detect, Respond	Signature lag; behavioural engines add overhead
Firewall (FW)	Unauthorised network access	Protect	Over-permissive rules create false assurance
IDS / IPS	Attack traffic detection and blocking	Detect, Respond	Rule tuning burden; encrypted traffic blind spots
VPN client/gateway	Eavesdropping and MITM on transit	Protect	Protects the tunnel only, not the endpoint
SIEM	Log aggregation and threat correlation	Identify, Detect, Respond, Recover	Dependent on log quality; alert fatigue risk
DLP	Data exfiltration via email / USB / cloud	Protect, Detect	Classification accuracy determines coverage
Vulnerability Scanner (VA)	Known vulnerabilities in software/config	Identify	Point-in-time snapshot; misses zero-days
PAM	Credential theft and privilege escalation	Protect, Detect	Only covers enrolled accounts; shadow admins evade

A-2 Defence in Depth - Software Layer Mapping

NIST SP 800-53 and CIS Controls v8 both prescribe layered controls rather than reliance on a single product. The table below maps security software families to their position in a defence-in-depth architecture and the rationale for each layer.

Layer	Software categories	Rationale
Perimeter	NGFW, inline IPS, VPN gateway	Controls ingress/egress; forms the first boundary attackers must cross.
Network internal	IDS (passive tap), SIEM log ingestion, DLP proxy	Detects lateral movement and exfiltration after a perimeter bypass.
Host	AV/EDR, host firewall, HIDS, VA scanner	Last-resort detection and containment at the point of code execution.
Identity	PAM, MFA enforced by IAM tooling	Limits credential-based lateral movement and insider escalation.
Data	DLP agent, encryption at rest	Protects the asset even when all outer layers have been compromised.

The core insight is that no single tool is the last line of defence. Each layer assumes the previous one has been bypassed and provides independent detection or containment capability.

Part B - Tool Evaluation and Hands-on Lab

B-1 Windows Defender Evaluation Matrix

Windows Defender (Microsoft Defender Antivirus) was evaluated against NIST SP 800-83 and CIS Control 10 criteria. It was selected because it is the default Windows endpoint protection baseline in many small organisations.

Criterion	Rating	Evidence and recommendation
Signature coverage	Meets	Definitions updated multiple times daily; EICAR detected immediately. Validate update policy not delayed by GPO.
Behavioural / heuristic detection	Partial	Cloud heuristics (MAPS) available but require connectivity; air-gapped hosts lose this layer. Enable MAPS and sample submission.
Real-time (on-access) protection	Meets	EICAR blocked on file-write without manual scan trigger; Event ID 1116 logged. Enforce via Group Policy: <code>DisableRealtimeMonitoring = 0</code> .
Scheduled full scan	Partial	Default schedule exists but is configurable by users without admin friction. Enforce centrally via Intune or GPO; alert on missed scans.
Logging / SIEM integration	Partial	Logs to Windows Event Log (IDs 1116, 1117, 5001); WEF forwarding to SIEM requires explicit configuration. Configure WEF for Defender Operational log.
Tamper protection	Meets	Service stop blocked for non-admin; access denied returned on <code>sc stop WinDefend</code> . Verify via <code>Get-MpPreference Select TamperProtection</code> .
Ransomware / Controlled Folder Access	Partial	Feature present but disabled by default. Enable and allow-list trusted apps before rollout to avoid workflow disruption.
Incident response integration	Gap	Standalone Defender lacks automated playbooks, network isolation, or ticketing without Defender for Endpoint or SOAR. Supplement with Wazuh + scripted isolation.

B-2 Hands-on Detection Tests

Test 1 - EICAR standard test file. The EICAR test file was written to the Desktop of a Windows 11 host with real-time protection enabled. The file was removed within approximately two seconds of creation. A Windows Security notification appeared reading “*Threat found: Virus:DOS/EICAR_Test_File*” and Event ID 1116 was recorded in the `Microsoft-Windows-Windows Defender/Operational` event log with action `Quarantine`. Result: **PASS**.

Test 2 - EICAR inside a ZIP archive. The EICAR string was packaged into a .zip archive before writing. The archive itself was not deleted on creation. When extraction was attempted, Defender blocked the decompression and logged Event ID 1116 with the compressed file path. This confirms that Defender scans compressed content at the point of access rather than on archive creation alone. Result: **PASS**.

Test 3 - Tamper protection (service stop attempt). The command `sc stop WinDefend` was executed from a standard user account. The command returned “Access Denied” (error 5) and no Event ID 5001 (service disabled) was generated. Tamper Protection prevented the service termination. Result: **PASS**.

B-3 Windows Firewall Rule Audit

A review of the default Windows Firewall rule set identified the following findings relevant to the lab environment.

Dir.	Rule	State	Action	Risk commentary
Inbound	Remote Desktop (TCP 3389)	Enabled	Allow	Open on all profiles; brute-force and credential-stuffing risk if internet-reachable. Scope to management source IPs.
Inbound	File and Printer Sharing (SMB, TCP 445)	Enabled	Allow	Acceptable on domain profile; on public profile widens lateral movement surface for ransomware.
Outbound	All outbound (default allow)	Enabled	Allow	Malware with C2 beaconing is unblocked. An outbound allow-list significantly limits exfiltration viability.
Inbound	ICMP Echo Request (ping)	Disabled	Block	Correct default on public profile; reduces host discovery exposure on untrusted networks.

Part C - Advisory Report

For: Head of Department, University Computing Services

Re: Minimum-viable security software stack for a department of approximately 50 users

The six recommendations below are prioritised and implementable with free or open-source tools. Effort indicates expected deployment complexity.

#	Control area	Current gap	Recommended action (tool / effort)
1	Endpoint protection	Defender enabled but unmanaged and unreported	Enforce Tamper Protection, Controlled Folder Access, and daily-update policy via Group Policy. Forward Event IDs 1116/1117 to a central log store. (<i>Low effort</i>)
2	Firewall hardening	RDP and outbound-all open by default	Restrict inbound RDP to management network; implement outbound allow-list for known applications. (<i>Low effort</i>)
3	Centralised logging	No aggregation; events isolated per host	Deploy Wazuh (free) or Elastic Security. Alert on failed logon (4625), new accounts (4720), and malware detection (1116). (<i>Medium effort</i>)
4	Vulnerability management	Patching occurs but no scan-based gap verification	Monthly authenticated OpenVAS scans; remediate CVSS 9+ within 72 hours, CVSS 7+ within 30 days. (<i>Medium effort</i>)
5	Secure remote access	Direct RDP over open internet in use	Deploy WireGuard VPN; disable external RDP; require MFA on VPN authentication. (<i>Medium effort</i>)

6	Privileged access	Shared local admin credentials; no session audit	Deploy Microsoft LAPS (free) for unique local admin passwords; enforce just-in-time elevation logged to SIEM. (<i>Low effort</i>)
---	-------------------	--	---

Items 1, 2, and 6 can be implemented immediately at near-zero cost and address common breach patterns: unmonitored endpoint alerts, permissive firewall defaults, and shared credentials.

Part D - Synthesis and Reflection

The week reinforces a recurring portfolio pattern: impactful failures are usually misconfigurations rather than exotic zero-days. Defender passed all three tests, but its value is limited without centralised logging and response. Likewise, default-allow outbound policy and open inbound RDP materially weaken perimeter security.

This week connects directly to earlier modules: Week 6 showed OSINT-driven targeting, and Week 7 showed how exposed services and weak application controls enable foothold and persistence. Security software is the operational layer that can interrupt these paths, but only when configured, monitored, and integrated.

The key conclusion is that missing governance, not missing tools, is often the real weakness. Technology without enforceable policy remains incomplete security.